

Визначення показників RPO та RTO у відновленні після інцидентів

Домашнє завдання до теми 7

Кейс: ransomware-атака на інтернет-магазин

Мета документа

Визначити допустимі значення Recovery Point Objective (RPO) та Recovery Time Objective (RTO) для ключових систем організації, а також обґрунтувати технічні й організаційні заходи для досягнення цих показників.

Зміст

1. Опис обраної загрози
2. Визначення допустимого RPO для різних систем
3. Визначення допустимого RTO для різних систем
4. Заходи для забезпечення RPO та RTO
5. Приклад розрахунків для Google Sheets
6. Висновок

Коротко про показники

RPO відповідає на питання: “Скільки даних можна втратити?” RTO відповідає на питання: “За який максимальний час система має бути відновлена?” Чим критичніша система, тим меншими мають бути ці показники.

1. Опис обраної загрози

Обрана загроза: ransomware-атака на інтернет-магазин.

Сценарій інциденту: шкідливе програмне забезпечення зашифрувало основний сервер сайту, базу замовлень, частину CRM та файлове сховище. Організація повинна відновити роботу сайту, зберегти замовлення клієнтів, фінансові операції та мінімізувати час простою.

Ключовий принцип

Для систем, що напряду забезпечують продажі та обробку платежів, встановлюються найменші RPO та RTO. Для допоміжних систем допускаються більші показники, якщо це не зупиняє основний бізнес-процес.

2. Визначення допустимого RPO для різних систем

RPO визначає максимальний обсяг даних, який організація може дозволити собі втратити після інциденту без критичних наслідків. Для інтернет-магазину найменші втрати допустимі для замовлень і платіжних операцій, оскільки саме вони напряду впливають на дохід та довіру клієнтів.

Таблиця 1. Допустимий RPO для систем інтернет-магазину

Система	Критичність	Допустимий RPO	Що це означає?	Як часто потрібно резервувати?
База замовлень інтернет-магазину	Висока	5 хвилин	Компанія може втратити максимум 5 хвилин нових замовлень без критичних наслідків.	Реплікація майже в реальному часі + резервна копія кожні 5 хвилин.
Платіжні транзакції	Висока	0-5 хвилин	Втрата платіжних даних неприпустима або має бути мінімальною.	Використання зовнішнього платіжного провайдера + журналювання транзакцій.
Складський облік товарів	Середня	30 хвилин	Можлива незначна неточність у залишках товарів, яку можна звірити після відновлення.	Резервне копіювання кожні 30 хвилин.
CRM із даними клієнтів	Середня	1 година	Втрата частини нових контактів або звернень клієнтів за останню годину є небажаною, але не критичною.	Резервне копіювання щогодини.
Файлове сховище документів	Низька/середня	12 годин	Документи змінюються не так часто, тому допустима втрата останніх змін за пів дня.	Резервне копіювання 2 рази на день.
Логи безпеки та системні журнали	Середня	24 години	Частина логів може бути втрачена, але бажано зберегти їх для розслідування інциденту.	Щоденне архівування + передача логів у SIEM.

3. Визначення допустимого RTO для різних систем

RTO визначає максимальний час, протягом якого система може бути недоступною після збою або атаки. Для інтернет-магазину критичним є швидке відновлення сайту, бази замовлень та платіжної інтеграції, оскільки простій безпосередньо призводить до втрати продажів.

Таблиця 2. Допустимий RTO для систем інтернет-магазину

Система	Критичність	Допустимий RTO	Що це означає?	Чи потрібні високонадійні рішення?
Сайт інтернет-магазину	Висока	30 хвилин	Сайт має бути доступний для клієнтів максимум через 30 хвилин після інциденту.	Так, потрібен резервний сервер або хмарне середовище.
База замовлень	Висока	1 година	Замовлення мають бути відновлені максимум за 1 годину, інакше бізнес втрачатиме продажі.	Так, потрібна реплікація бази даних.
Платіжна інтеграція	Висока	1 година	Клієнти повинні знову мати можливість оплачувати замовлення протягом 1 години.	Так, потрібен резервний канал або зовнішній провайдер.
Складський облік	Середня	3 години	Працівники складу можуть тимчасово працювати вручну, але не довше 3 годин.	Бажано мати резервну копію та окремий сервер.
CRM та підтримка клієнтів	Середня	4 години	Відділ підтримки може працювати з обмеженнями, але тривалий простій погіршить сервіс.	Потрібне хмарне резервування.
Файлове сховище	Низька/середня	8 годин	Документи не є критичними для миттєвого продажу, тому можуть бути відновлені пізніше.	Достатньо стандартного резервного копіювання.
Логи безпеки	Середня	12 годин	Логи важливі для аналізу атаки, але не обов'язково відновлювати їх першими.	Потрібне архівне сховище та централізований збір логів.

4. Заходи для забезпечення RPO та RTO

Щоб досягти зазначених показників RPO та RTO, організація повинна поєднати технічні засоби резервного копіювання, автоматичне перемикання на резервну інфраструктуру, захист резервних копій від зміни та регулярне тестування відновлення.

Таблиця 3. Обґрунтування заходів відновлення

Захід відновлення	Що захищає?	Для яких систем?	Як забезпечує RPO/RTO?	Чому це важливо?
Реплікація бази даних у реальному часі	Замовлення, платежі, клієнтські дані	База замовлень, платіжні транзакції, CRM	Дає RPO 0-5 хвилин, бо дані майже одразу дублюються.	Мінімізує втрату критичних бізнес-даних.
Автоматичне перемикання на резервний сервер	Доступність сайту та бази даних	Сайт, база замовлень	Допомагає досягти RTO 30-60 хвилин.	Зменшує час простою після атаки.

Захід відновлення	Що захищає?	Для яких систем?	Як забезпечує RPO/RTO?	Чому це важливо?
Інкрементальні резервні копії	Зміни в базах даних і файлах	CRM, складський облік, файлове сховище	Дозволяє часто зберігати зміни без великого навантаження.	Дає змогу відновити останні актуальні дані.
Immutable backups — незмінювані резервні копії	Захист від шифрування резервних копій	Усі критичні системи	Дозволяє відновитися навіть після ransomware.	Зловмисники не зможуть змінити або видалити копії.
Окреме хмарне резервне середовище	Роботу бізнесу після повного збою основної інфраструктури	Сайт, база замовлень, CRM	Дає швидке відновлення сервісів у хмарі.	Потрібне, якщо основний сервер повністю недоступний.
Централізований збір логів	Дані для розслідування інциденту	Логи безпеки, системні журнали	Дає змогу не втратити важливі сліди атаки.	Допомагає зрозуміти, як сталася атака.
Регулярне тестування відновлення	Перевірка працездатності резервних копій	Усі системи	Підтверджує, що RPO та RTO реально досяжні.	Без тестування резервні копії можуть виявитися непридатними.

5. Google Sheets

Таблиця 4. Приклад розрахунків RPO та RTO

Система	Інтервал backup, хв	Затримка реплікації, хв	RPO, хв	Час запуску резервного сервера, хв	Час перевірки системи, хв	RTO, хв
База замовлень	5	0	5	40	20	60
Сайт	15	0	15	20	10	30
CRM	60	0	60	180	60	240
Складський облік	30	0	30	120	60	180
Файлове сховище	720	0	720	360	120	480

6. Висновок

- Для інтернет-магазину найкритичнішими системами є сайт, база замовлень і платіжні транзакції, тому для них потрібно встановити найменші значення RPO та RTO.
- Найкращими заходами для такого кейсу є реплікація даних, автоматичне перемикання на резервний сервер, immutable backups і регулярне тестування відновлення.
- Менш критичні системи, наприклад файлове сховище або архівні логи, можуть мати більші RPO та RTO, оскільки їх тимчасова недоступність не зупиняє основний бізнес-процес — приймання та оплату замовлень.